E-COMMERXE®

SOFTWARE REQUIREMENTS SPECIFICATION DOCUMENT - [SRS]

1. **INTRODUCTION**

1.1 Orientation:

This document defines the Software Requirements Specification (SRS) for a multi-tenant e-commerce backend powering a digital business advertising platform. Business owners create accounts, publish digital business cards, and operate within a centralized "virtual mall" where consumers discover and interact with businesses.Its definitely a digital marketing client

The backend prioritizes fast time-to-market, strict tenant isolation, and scalability on demand.

1.2 Scope:

a. In Scope (MVP):

Feature Area	Description
User Management	Registration, authentication, role-based access
Business Management	CRUD, category assignment, soft delete

Business Cards	Public-facing cards with SEO-friendly URLs
Search & Discovery	PostgreSQL full-text search, faceted filtering
Media Management	Image upload, validation, CDN delivery
Analytics Engine	Views/clicks tracking, per-business dashboard
Multi-Tenancy	Row-Level Security (RLS) data isolation
Security	OWASP Top 10 mitigations, rate limiting, encryption

b. Out of Scope (v2.0+):

- ❿ Payment processing
- ❿ AI-powered ranking
- ❿ Geo-location search
- ❿ Real-time chat
- ❿ Elasticsearch (start with PG full-text)

2. **SYSTEM ARCHITECTURE**

2.1 ***Architecture Style:***

Modular Monolith (deployable as microservices later)

```
┌──────────────────────────────────────────────────┐
│        API Gateway (Nginx + Lua)          │
│  Rate Limiting │ JWT Auth │ WAF (Cloudflare) │
└──────────────────────────────────────────────────┘
                │
┌───────────────┼──────────────────────────────┐
▼               ▼               ▼
┌──────────┐  ┌──────────┐  ┌──────────┐
│  Auth    │  │Business  │  │ Search   │
│ Module   │  │ Module   │  │ (PG FTS) │
└──────────┘  └──────────┘  └──────────┘
                │
┌───────────────┼──────────────────────────────┐
▼               ▼               ▼
┌──────────┐  ┌──────────┐  ┌──────────┐
│PostgreSQL│  │ Redis    │  │ S3/R2    │
│ (Primary │  │(Cache +  │  │ (Images) │
│ + RLS)   │  │ Queue)   │  │          │
└──────────┘  └──────────┘  └──────────┘
```

2.2 ***Technology Stack (MVP):***

Layer	Technology	Notes
Runtime	Node.js v20+	LTS
Framework	NestJS v10+	Strict TypeScript
Cache/Queue	Redis v7+	Single instance (not cluster)
Database	PostgreSQL v15+	RLS enabled, full-text search
Object Storage	Cloudflare R2	S3-compatible, no egress fees
Auth	JWT (RS256) + refresh tokens	15min / 7 days
API Gateway	Nginx	Built-in rate limiting
Observability	Prometheus + Grafana	Tenant-tagged metrics
Deployment	Docker + Docker Compose	K8s in v2.0

3. **CORE MODULES**

3.1 ***Authentication Module:***

Feature	Implementation
Registration	Email + password, OAuth 2.0 (Google), email verification required + OTP verification + capchas(cloudflare)
Login	JWT access token (RS256, 15min) + HTTP-only refresh cookie
Password Security	Argon2id hashing
Session	Redis-backed, 30min idle timeout
Account Lockout	5 failures → 15min lockout – notify registered account owner via his email
Logout	Token blacklist + refresh token rotation
Password Reset	Time-limited signed URL (15min)

Rate Limits (Nginx):

/auth/login: 5/min per IP

/auth/register: 3/min per IP

/auth/password-reset: 3/hour per IP

3.2 ***User Module:***

Role	Permissions
Sudo Admin	Full system access, moderation, audit logs, delte specified account
Business Owner	CRUD own businesses, view own analytics, delete own account

Visitor	View public cards, search, message business owner,leave a rating
GDPR:	Data export (/api/v1/user/export) + deletion (30-day grace)

3.3 ***Business Module:***

Feature	Specification
Create	Max 5 businesses per account, unique slug, category (1-3)
Update	Audit log, immutable created_at
Delete	Soft delete, 30-day recovery grace
Verification	Email confirmation + optional admin review
Multi-Tenancy PostgreSQL RLS:	tenant_id = current_setting('app.current_tenant')

3.4 Business Card Module:

Feature	Specification
Public Access	No auth, CDN-cached (<100ms)
Components	Logo, banner, name, categories, description, CTA buttons
SEO	Meta tags, Open Graph, Schema.org/LocalBusiness
Customization	5 templates (MVP)
URL Immutability	Slug changes → 301 redirect (stored in redirects table)

3.5 Media Module:

Feature	Specification
Upload	JPG/PNG/WebP/AVIF, max 10MB, max 20 files/business
Validation	Magic number verification, ClamAV scan
Processing	Auto-resize (thumbnail, small, medium, banner), WebP convers
Storage	R2/S3 with SSE encryption, presigned URLs (15min expiry)
CDN	Cloudflare (free tier for MVP)
EXIF	Stripped automatically
Rate limit:	10 uploads/min per user

3.4 ***Search Module (PostgreSQL Full-Text, no ES):***

Feature	Specification
Searchable Fields	Business name, description, category names, tags
Faceted Filters Category,	verification status
Ranking	Relevance (ts_rank) + recency (days since update)
Typo Tolerance	PostgreSQL pg_trgm similarity
Performance	<300ms p95
Index:	GIN index on search_vector column

3.7 Analytics Module:

Feature	Specification
Events	Card views, clicks, CTA actions
Storage	PostgreSQL (monthly partitioning)
Real-time Redis counters	batched to DB every hour
Dashboard	7/30/90-day views/clicks per business
Privacy	IP anonymization (last octet zeroed)

Event Schema:

```
json
{
  "event_id": "uuid",
  "tenant_id": "uuid",
  "business_id": "uuid",
  "event_type": "view|click|cta",
  "timestamp": "ISO8601",
  "session_id": "hash",
  "ip_hash": "sha256(anonymized)",
  "referrer": "domain-only"
}
```

3.8 Admin Module:

Feature	Implementation
User Mgmt	Suspend/activate, role changes
Business Moderation	Approve/flag content
System Health	Per-tenant metrics (Prometheus)

Audit Logs	Append-only table (truncate protected)

4. **FUNCTIONAL REQUIREMENTS**

ID	Requirement	Priority
FR-001	Register with email/password or Google OAuth	Must
FR-002	Email verification required before activation	Must
FR-003	Update profile with validation	Must
FR-004	Data export (GDPR) within 30 days	Must
FR-005	Account deletion with 30-day grace	Must
FR-006	Max 5 businesses per account	Must
FR-007	SEO-friendly slug (unique)	Must
FR-008	Soft delete with 30-day recovery	Must
FR-009	Public card access without auth	Must
FR-010	Mobile/responsive rendering	Must
FR-011	Search by name, category, keywords (PostgreSQL FTS)	Must
FR-012	Category filtering	Must
FR-013	Image upload (JPG/PNG/WebP/AVIF, ≤10MB)	Must
FR-014	Malware scan before processing	Must
FR-015	Track every view and click	Must
FR-016	Per-business analytics dashboard	Must

5. **NON-FUNCTIONAL REQUIREMENTS**

5.1 Performance:

Metric	Target
API (cached)	<100ms p95
API (uncached)	<300ms p95
Search	<300ms p95
Card render	<100ms p95 (CDN)
Upload processing	<5s p99

5.2 Scalability :

Stateless API → horizontal scaling ready

Read replicas for analytics queries
Redis single instance (cluster in v2.0)

5.3 Security (Defense in Depth):

Layer	Controls
Network	TLS 1.3, Cloudflare WAF, DDoS protection
App	Input validation (Zod), parameterized queries, CSP, HSTS
Auth	Argon2id, JWT RS256, refresh rotation, optional MFA
Authorization	RBAC + RLS (database-enforced)
Data	AES-256 at rest, TLS 1.3 in transit
Audit	Immutable logs + SIEM (ELK)

5.4 Reliability (MVP):

Metric Target
Uptime 99.5%
RTO 4 hours
RPO 1 hour
Error logging Winston + Sentry

5.5 Maintainability:

Modular monolith (domain boundaries)
OpenAPI 3.0 / Swagger
Test coverage: Unit ≥80%, Integration ≥60%
ESLint + Prettier enforced in CI

6. **DATABASE DESIGN**

Entity Relationship (Key Tables)
text
```
users (id, email, password_hash, role, mfa_secret, created_at)
  │
  └─1:M── businesses (id, owner_id, tenant_id, name, slug, verified, deleted_at)
          │
          ├─1:1── business_cards (id, business_id, slug, template_id, seo_metadata)
          │
          ├─1:M── media_files (id, business_id, file_url, cdn_url, file_type)
          │
          └─1:M── analytics_events (id, tenant_id, business_id, event_type, timestamp,
ip_hash)

categories (id, name, slug, parent_id) ──M:M── business_categories (junction)
```
Multi-Tenancy (RLS)
sql
```
-- Applied to businesses, media, analytics
CREATE POLICY tenant_isolation ON businesses
```

```
    USING (tenant_id = current_setting('app.current_tenant')::UUID);

-- Application sets context per request
SET app.current_tenant = 'tenant-uuid-from-jwt';
```

Why shared schema + RLS: Lowest cost, database-enforced isolation, no developer mistakes possible. Enterprise tenants → migrate to schema-per-tenant later.

7. API STRUCTURE

Authentication(public):

Method	Endpoint	Description
POST	/api/v1/auth/register	Register
POST	/api/v1/auth/login	Login (sets refresh cookie)
POST	/api/v1/auth/refresh	Rotate token
POST	/api/v1/auth/logout	Logout
POST	/api/v1/auth/mfa/enable	Enable TOTP (optional)
POST	/api/v1/auth/password-reset	Request reset
POST	/api/v1/auth/password-reset/confirm	Confirm reset

Businesses (Bearer + RLS):

Method	Endpoint	Auth
POST	/api/v1/businesses	Owner
GET	/api/v1/businesses/:id	Owner (full) / Public (basic)
PUT	/api/v1/businesses/:id	Owner
DELETE	/api/v1/businesses/:id	Owner

Public Cards (No Auth):

Method	Endpoint
GET	/api/v1/cards?page=&limit=
GET	/api/v1/cards/:slug

Search (No Auth):

Method	Endpoint
GET	/api/v1/search?q=&category=&page=&limit=

Analytics:

Method	Endpoint	Auth
POST	/api/v1/analytics/events	Signed payload (frontend)
GET	/api/v1/analytics/dashboard	Owner

Admin:

Method	Endpoint	Auth
GET	/api/v1/admin/users	Sudo Admin
PUT	/api/v1/admin/users/:id/suspend	Sudo Admin
GET	/api/v1/admin/audit-logs	Sudo Admin

8. SECURITY HEADERS

Strict-Transport-Security: max-age=63072000; includeSubDomains; preload
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Referrer-Policy: strict-origin-when-cross-origin
Content-Security-Policy: default-src 'self'; script-src 'self' 'nonce-{random}'; img-src 'self' https://cdn.example.com data:
Permissions-Policy: geolocation=(), microphone=(), camera=()

9. DEPLOYMENT PIPELINE

Push → Lint (ESLint) → Unit Tests (Jest) → Security Scan (Snyk) → Build (Docker) → Deploy Canary (5% → 100%)

Infrastructure: Docker Compose (MVP) → Kubernetes (v2.0)
Cloud: DigitalOcean Kubernetes (cost-optimized) or AWS ECS
Backup: PostgreSQL daily snapshots + 1 hour PITR, R2 cross-region replication

10. TESTING STRATEGY

Type	Coverage	Tools
Unit	≥80%	Jest
Integration	≥60%	Jest + Supertest
E2E	Critical paths	Playwright
Security	OWASP	Top 10 OWASP ZAP (CI)
RLS	100%	Custom test suite

11. LOGIC PLEDGE:

*The backend should work perfectly having modern implementations and the database should be highly able to accommodate data of thousands of users at once, thousands of various requests can happen at once without crashing the system and there should be fast responsiveness.API keys shouldn’t be hard-coded in the source code, no querying of data

unethically e.g in a URL,have an API rate limiting...

--END OF DOCUMENT--

E-COMMERXE®